

Atelier professionnalisant - Groupe 3

SLAM : Rayane - Lénaïck - Téo - Thomas SISR : Farid - Marik

Chef de projet : Téo



Titre : Rapport préparatoire – Analyse de conformité légale et propositions techniques de sécurisation des données

Date : 17/09/2025

Rédigé par : Poulle Téo - Groupe 3

Sommaire :

I. Introduction.....	3
II. Rapport de la conformité légale.....	4
1. Principes de base du RGPD.....	4
2. Obligations légales.....	5
3. Actions à entreprendre.....	7
III. Propositions techniques pour la sécurité des données.....	9
1. La sécurité du réseau.....	9
2. La sécurité des données.....	12
IV. Conclusion.....	15
V. Sources des recherches.....	16

I. Introduction

Dans le cadre du projet d'évolution du système d'information de la clinique Pasteur, notre équipe s'est vue attribuer la réalisation d'un travail préparatoire visant à garantir la conformité légale et la sécurité technique du traitement des données. Ce travail préparatoire a été réalisé par : DUVIVIER Thomas, GUENOUNOU Farid, POULLE Téo, RAYNAL Marik, SALFI Rayan et YENON Lénaïck.

Ce rapport abordera deux volets complémentaires :

- Une analyse de la conformité légale, notamment au regard du Règlement Général sur la Protection des Données (RGPD) et des obligations associées ;
- La proposition de solutions techniques permettant d'assurer la sécurité, la confidentialité et l'intégrité des données traitées.

L'objectif est de fournir une base claire et documentée afin d'orienter les choix techniques et organisationnels du projet tout en assurant le respect de la réglementation en vigueur.

II. Rapport de la conformité légale

1. Principes de base du RGPD

Le Règlement Général sur la Protection des Données (RGPD – Règlement (UE) 2016/679) encadre strictement le traitement des données personnelles, en particulier celles considérées comme sensibles. Les données relatives à la santé sont expressément incluses dans cette catégorie, car leur divulgation peut avoir des conséquences importantes pour la vie privée des patients.

Pour un établissement de santé, le respect du RGPD est essentiel à la fois pour garantir la confiance des patients et pour éviter d'éventuelles sanctions administratives ou judiciaires.

Par son article 9, le RGPD expose un principe clair : « Le traitement des données à caractère personnel qui révèlent l'origine raciale ou ethnique, les opinions politiques, les convictions religieuses ou philosophiques ou l'appartenance syndicale, ainsi que le traitement de données génétiques, de données biométriques aux fins d'identifier une personne physique de manière unique, de données concernant la santé ou de données concernant la vie sexuelle ou l'orientation sexuelle d'une personne physique est interdit. »

Expliquer autrement, le traitement des données de santé est interdit par défaut. Toutefois, le RGPD prévoit certaines exceptions, évidemment très encadrées. Le consentement explicite et révocable à tout moment du patient ou la nécessité d'enregistrement des soins médicaux lorsque le traitement est indispensable en sont deux exemples. L'intérêt public dans le domaine de la santé constitue également une condition de contournement de ces règles, il est possible de citer à titre d'exemple la surveillance des épidémies ou la protection contre les menaces sanitaires graves.

De plus, le RGPD exprime de nombreux autres principes que les organismes de santé se doivent de respecter. Le personnel médical est dans l'obligation d'être transparent sur l'utilisation des données d'un patient, et donc, de l'en informer. Il est également nécessaire de mettre en place des mesures techniques et organisationnelles pour assurer la sécurité des données de santé.

Tout organisme manipulant des données à caractère personnel doit nommer un délégué à la protection des données (ou DPO) qui sera chargé de superviser la conformité de l'établissement aux différentes obligations légales.

Par ailleurs, le personnel médical et administratif doit être en mesure de garantir les droits des patients tels que le droit d'accès, de rectification ou de l'effacement de leurs données. De plus, seules les données essentielles et nécessaires pour atteindre les objectifs visés par l'organisme de santé peuvent être collectées et enregistrées.

2. Obligations légales

Dans l'exercice de leur profession, le personnel médical est soumis à un certain nombre d'obligations légales visant à protéger les patients et à garantir la qualité des soins. Il nous est pertinent de mentionner certaines d'entre-elles.

Le devoir d'information impose au médecin de fournir aux patients des informations claires, complètes et adaptées concernant leur état de santé, les examens proposés, les traitements envisagés ainsi que leurs risques. Cette obligation est codifiée à l'article R4127-35 du Code de la santé publique.

Le devoir de secret professionnel exige que le médecin préserve la confidentialité des informations obtenues dans le cadre de sa pratique. Cela couvre non seulement ce qui lui est directement confié, mais également tout ce qu'il a vu, entendu ou compris lors de l'exercice de sa profession. Cette obligation est définie par l'article R4127-4 du Code de la santé publique.

Par principe, le traitement des données de santé est interdit sauf dans des cas particuliers, cas mentionnés dans les articles 9 du RGPD et 6 de la Loi Informatique et Liberté (LIL). Elles peuvent toutefois être traitées sous plusieurs conditions, conditions également mentionnées dans les articles 9.2 du RGPD et 44 de la LIL.

La Loi Informatique et Liberté prévoit des formalités préalables auprès de la CNIL concernant les traitements de données de santé. L'article 65 prévoit des cas où l'accomplissement de formalités n'est pas nécessaire.

Ces formalités ne seront pas nécessaires dans le cas où la personne à donner son consentement de manière explicite, si le traitement est réalisé par un organisme à but non lucratif poursuivant une finalité prévue par les textes ou encore si le traitement est nécessaire à des fins de médecines préventives, de diagnostics médicaux et bien d'autres. Cette liste d'exception est exhaustive et consignée sur plusieurs sites tel que celui de la Commission Nationale de l'Informatique et des Libertés (CNIL).

La sécurité des données est également assurée par le Système National des Données de Santé (SNDS). Ce système préconise notamment la pseudonymisation des données, c'est-à-dire que toutes informations permettant d'identifier un individu doivent être remplacées par un pseudonyme (un code alphanumérique). Une authentification forte est exigée pour contrôler les accès et associer une action à une personne. Tous les événements relatifs à la sécurité du système doivent être tracés afin de contrôler l'utilisation des données et de disposer de preuves en cas de litige. Il faut s'assurer que l'utilisation des données est conforme à la loi par le biais d'audits. Enfin, la sensibilisation et la formation des utilisateurs et administrateurs sont très importantes pour garantir la sécurité des données de santé.

D'un autre côté, les patients possèdent de nombreux droits envers le traitement de leurs données, il est à la charge de l'organisme de les prévenir quant à l'existence de ces droits.

Le droit d'être informé consiste à ce que les patients aient un accès simple à ces informations, un bon aperçu de l'utilisation de leurs données et d'être informé à tout moment, surtout si la sécurité des données est compromise.

Le droit d'accès est défini par la connaissance précise des données que l'organisme détient. Le droit à la portabilité est le fait de permettre l'obtention de ses données personnelles par un quelconque moyen.

Le droit à la rectification, en cas de données incorrectes, incomplètes ou obsolètes, le patient doit pouvoir demander leurs rectifications ou complétions dans un délai raisonnable.

Le droit d'opposition a pour effet de permettre au patient de refuser à tout moment que l'organisme collecte et/ou utilise certaines données. Cette demande doit être effectuée par écrit ou courriel en précisant les traitements auxquels celui-ci s'oppose.

Le droit au déréférencement est le fait de demander à ce que certains résultats soient retirés des moteurs de recherche.

Les droits liés au profilage et aux décisions automatisées consistent à refuser toute décision automatique et/ou demander l'intervention humaine dans la prise de décision.

Enfin, le droit au recours et de réparation du dommage matériel ou moral qui permet au patient d'avoir recours aux litiges.

3. Actions à entreprendre

Il est nécessaire de recenser les traitements de données, d'informer les personnes concernées et limiter leur collecte. Il faut garantir les droits (accès, rectification, effacement, opposition), sécuriser les données (chiffrement, accès, sauvegardes) et encadrer les sous-traitants. Il est obligatoire de déclarer toute violation à la CNIL et fixer des durées de conservation avec suppression des données obsolètes.

Tenir les registres comptables et fiscaux à jour, respecter les obligations sociales (contrats, déclarations, sécurité au travail) et commerciales (mentions légales, CGV, droit de la consommation) sont des obligations légales à respecter impérativement. Il faut également assurer l'archivage réglementaire et se conformer aux exigences d'assurance et de protection des salariés.

Afin de garantir la conformité au RGPD dans le cadre des études cliniques et du traitement des données de santé, plusieurs actions peuvent être mises en œuvre.

La mise en place d'une gouvernance claire est essentielle. Il est nécessaire de nommer ou de confirmer un Délégué à la Protection des Données (DPO) chargé de superviser la conformité. Un registre des traitements doit être établi pour recenser l'ensemble des données collectées et utilisées. Les responsabilités doivent être clairement définies entre les différents services (médecins, chercheurs, DSI, personnel administratif) et une politique de confidentialité adéquate doit être diffusée afin de formaliser les bonnes pratiques internes.

Les patients doivent recevoir des informations claires et compréhensibles sur l'utilisation de leurs données. Le consentement explicite, écrit et horodaté, doit être recueilli conformément à l'article 9 du RGPD pour la participation aux études et le traitement des données de santé. Des mécanismes simples doivent être mis en place pour permettre aux patients d'exercer leurs droits (accès, rectification, effacement, opposition, portabilité), et la possibilité de retirer leur consentement à tout moment doit être garantie. L'information sur les droits des patients constitue un élément central de la conformité.

La protection des données passe par la mise en place de mesures techniques robustes. L'authentification forte (MFA, mots de passe robustes) et la gestion des accès basée sur les rôles (RBAC) avec le principe du moindre privilège doivent être systématiquement appliquées. Les données doivent être chiffrées, tant en transit (TLS/SSL) qu'au repos (bases de données chiffrées). La journalisation et la traçabilité des accès et des actions sur les données doivent être assurées, avec conservation sécurisée des logs et suivi des flux de données entre les services et les organismes externes. Enfin, des sauvegardes régulières, chiffrées et testées, garantissent la résilience des systèmes.

Le personnel médical et administratif doit être formé et sensibilisé aux enjeux de la protection des données de santé. Les outils existants doivent être sécurisés, en remplaçant progressivement les fichiers Excel et documents papier par une base centralisée. Un plan de gestion des incidents doit être établi, incluant les procédures internes et la notification à la CNIL sous 72 heures en cas de violation. La durée de conservation des données doit être clairement définie et respectée.

Des audits réguliers de conformité et de sécurité doivent être réalisés pour identifier les risques et ajuster les procédures. Les évolutions légales ou des protocoles médicaux doivent être intégrées dans les pratiques internes. Des outils d'anonymisation peuvent être utilisés pour l'analyse statistique et le partage des données avec les organismes centralisateurs. Un processus clair de détection, gestion et notification des violations à la CNIL et aux personnes concernées, dans un délai maximal de 72 heures, doit être défini. Enfin, un plan de continuité et de reprise d'activité garantit la résilience en cas d'incident majeur.

III. Propositions techniques pour la sécurité des données

1. La sécurité du réseau

Afin de garantir la confidentialité, l'intégrité et la disponibilité des données issues des études cliniques (QLQ-C30, QLQ-CR29, ReCaRe, CANTO, TAILORx), la Clinique Pasteur doit mettre en place un ensemble cohérent de mesures techniques et organisationnelles.

Les solutions ci-dessous couvrent à la fois la protection des données et la sécurisation de l'infrastructure réseau.

Résultats attendus :

- Conformité RGPD et respect du secret médical.
- Réduction des risques de fuite ou de perte de données sensibles.
- Fiabilité et disponibilité accrues pour l'ensemble des projets d'études cliniques.

Premier point la Sécurité des données

1-1 Chiffrement et protection des accès

-Chiffrement AES-256 des bases de données au repos. (Le chiffrement AES-256 est une mesure de sécurité qui consiste à brouiller (chiffrer) toutes les données stockées sur un disque dur à l'aide d'un algorithme très puissant (AES avec une clé de 256 bits). Seuls ceux qui possèdent la clé secrète peuvent les déchiffrer et les lire en clair.)

-Chiffrement des échanges (HTTPS/TLS 1.3) entre l'application web, l'application mobile et le serveur, (Le chiffrement des échanges via HTTPS/TLS 1.3 est comme créer un tunnel sécurisé et privé entre votre application (web ou mobile) et le serveur. Toutes les données qui voyagent dans ce tunnel sont brouillées (chiffrées). Même si quelqu'un intercepte la communication, il ne verra rien de compréhensible.)

-Authentification forte (MFA) pour les soignants, chercheurs et administrateurs. L'authentification forte (MFA) est une procédure de sécurité qui demande à un utilisateur de prouver son identité en utilisant au moins deux preuves différentes avant de lui donner accès à un système ou à des données. Pour un soignant, un chercheur ou un administrateur, cela signifie que pour se connecter au dossier patient ou à une base de données de recherche, il ne suffit plus de juste saisir un mot de passe. Il devra aussi, par exemple, saisir un code reçu sur son téléphone. C'est une barrière de sécurité critique qui protège les données les plus sensibles contre les accès non autorisés. Des réglementations comme le RGPD imposent des mesures de sécurité techniques et organisationnelles strictes pour protéger les données de santé. L'implémentation du MFA est une recommandation forte, voire une exigence, pour se conformer à ces textes.

-Gestion des accès selon le principe du moindre privilège (Le principe du moindre privilège est une règle de sécurité fondamentale qui stipule que tout utilisateur (ou programme, processus, système) ne doit disposer que des accès strictement nécessaires pour accomplir sa tâche, uniquement pour la durée requise, et rien de plus.)

1-2 Traçabilité et journalisation

-Mise en place d'un journal d'audit : connexion, consultation, modification. Un journal d'audit (ou log d'audit) est un enregistrement chronologique et immuable de tous les événements significatifs qui se produisent dans un système d'information. Ce journal servira à la détection des intrusions et des activités malveillantes, repérer des tentatives de connexion suspectes, des accès à des données en dehors des horaires de travail ou des modifications massives anormales. Il sert notamment à l'investigation après incident : comprendre comment une faille de sécurité s'est produite, quelles données ont été consultées, et évaluer l'étendue des dégâts. Enfin, le RGPD exige explicitement la mise en place de journaux d'audit pour prouver que les données sensibles sont contrôlées et surveillées.

-Conservation sécurisée des logs pendant 12 à 24 mois, avec alertes en cas d'accès anormal. Cela permet d'être conforme au règlement du RGPD qui exige de pouvoir démontrer la traçabilité des accès et traitements sur une période prolongée, souvent alignée sur des cycles d'audit annuels ou des délais légaux d'enquête. Cette conservation permet également de passer d'une analyse réactive (on regarde les logs on voit s'il y a un problème) à une détection proactive ("on est prévenu immédiatement d'un comportement suspect").

1-3 Sauvegardes et reprise après sinistre

-Sauvegardes chiffrées quotidiennes des bases de données et fichiers. Il s'agit de créer une copie de secours complète et chiffrée de toutes vos données critiques (bases de données et fichiers) tous les jours, et de la stocker de manière indépendante et sécurisée. L'intérêt principal est la protection contre les ransomwares : il s'agit de la menace n°1. Si un ransomware chiffre vos serveurs de production, des sauvegardes saines et isolées sont votre seul moyen de recovery sans payer la rançon. Résilience face aux sinistres : incendies, dégâts des eaux, pannes matérielles catastrophiques... Les sauvegardes permettent de redémarrer l'activité sur un nouvel environnement. Pour des questions de conformité : des réglementations comme le RGPD exigent que les données soient protégées contre la perte et l'accès non autorisé, ce qui inclut explicitement les copies de sauvegarde.

-Une stratégie de sauvegarde robuste suit presque toujours la règle 3-2-1 : trois copies des données (une copie utilisée et au moins deux copies de sauvegarde), deux supports de stockage différents : Par exemple, un disque dur NAS local ET un stockage cloud et une copie hors site : Une des copies doit être géographiquement distante du site principal pour survivre à un sinistre physique localisé (incendie, inondation).

Deuxième point : Bonnes pratiques organisationnelles

La formation régulière du personnel médical, administratif et informatique sur la sécurité et la confidentialité des données de santé est un point important.

Ces formations font partie d'un processus continu et obligatoire qui vise à enseigner, sensibiliser l'ensemble des collaborateurs d'un établissement de santé sur les règles, les bonnes pratiques et les risques liés à la manipulation des informations concernant la santé

des patients. L'objectif est de faire de chaque employé un acteur vigilant de la protection de ces données, qui sont extrêmement sensibles.

Cela se révèle indispensable sur plusieurs plans :

- Il s'agit d'une obligation légale stricte. En France, le Règlement Général sur la Protection des Données (RGPD) et les textes spécifiques comme la Loi Informatique et Libertés imposent des mesures techniques et organisationnelles pour protéger les données. Le non-respect de ces règles peut entraîner des sanctions très lourdes.
- La garantie que le secret des patients soit bien gardé est fondamentale pour la relation de confiance entre un patient et l'organisation.
- Le secteur de la santé est une cible de choix pour les cybercriminels. Le personnel est souvent le premier rempart contre les attaques de phishing ou les erreurs humaines

Plusieurs sujets doivent être abordés :

- Le cadre légal et les principes clés : RGPD, secret professionnel, principe de confidentialité, d'intégrité et de disponibilité des données.
- Les bonnes pratiques au quotidien : gestion de mot de passe, verrouillage de session, méfiance face aux emails, utilisation sécurisée des clés usb et des messageries, ne pas consulter de dossiers patients par curiosité.
- Procédures à suivre : qui contacter en cas de doute ou d'incident, comment signaler une perte ou vol de matériel.
- Rappel des conséquences encourues en cas de violation.
- Mise en situation basée sur des exemples réels pour illustrer les risques.

En résumé la formation régulière du personnel médical, administratif et informatique sur la sécurité et la confidentialité des données de santé est vraiment nécessaire et essentielle, ce qui permet de :

- Faire en sorte que les employés ne soient pas des maillons faibles.
- Protéger l'établissement contre des risques juridiques, financiers et de mauvaise réputation.
- Garantir aux patients que leurs données les plus intimes sont traitées avec le plus grand respect.

Cette formation est un cycle d'apprentissage, de rappels et de mises à jour face à l'évolution constante des menaces et de la réglementation.

2. La sécurité des données

La réduction des risques induits par l'usage des technologies numériques repose d'abord sur le respect de bonnes pratiques à adopter. À elles seules, ces dix règles d'or vous protégeront de la majorité des risques numériques qui pèsent sur vos usages personnels ou professionnels.

1- Séparez strictement vos usages

Avec l'avènement d'Internet et l'évolution des usages, la frontière entre vie professionnelle et vie personnelle devient de plus en plus poreuse. Pour sécuriser au mieux vos usages numériques dans ces différents environnements :

- Évitez d'utiliser vos moyens personnels (téléphone mobile, clé USB, etc.) à des fins professionnelles et inversement.
- N'utilisez pas votre adresse email professionnelle pour vous inscrire sur des sites Internet à titre personnel et réciproquement.
- Ne connectez pas d'équipements personnels, ou non fournis par votre service informatique, au réseau de votre entité ou à un équipement professionnel (téléphone mobile personnel, clé USB ou gadget électronique offert, etc.) ; ne connectez vos équipements professionnels sur votre réseau personnel que dans les conditions prévues par votre service informatique.

2- Mettez régulièrement à jour vos outils numériques

Un appareil ou un logiciel qui n'est pas à jour devient vulnérable. Après avoir identifié l'ensemble de vos appareils et logiciels :

- Appliquez les mises à jour dès qu'elles vous sont proposées.
- Téléchargez les mises à jour uniquement depuis les sites officiels des éditeurs.
- Activez l'option de téléchargement et d'installation automatique des mises à jour, quand elle existe.

3- Protégez vos accès

Il est important d'utiliser un mot de passe différent pour chaque accès (messagerie, banque en ligne, comptes de réseaux sociaux, etc.) afin d'éviter l'effet boule de neige en cas de compromission de l'un de vos comptes.

- Créez un mot de passe robuste (suffisamment long, complexe et aléatoire) de 12 caractères minimum et contenant des minuscules, des majuscules, des chiffres et des caractères spéciaux ; les phrases de passe (par exemple, une phrase prise au hasard dans un livre) constituent une bonne alternative parfois plus simple à mémoriser.
- Ne communiquez jamais votre mot de passe à un tiers : aucune organisation ou personne de confiance ne vous demandera de lui communiquer votre mot de passe.

4- Ne laissez pas vos équipements sans surveillance

Lorsque vous êtes en déplacement, veillez à ne jamais laisser vos appareils sans surveillance. Vous vous exposez au vol, à la manipulation et la compromission desdits matériels et de vos données.

Lorsque vous n'utilisez pas votre poste de travail (même au bureau et à la maison), pensez à le verrouiller et placer en lieu sûr l'ensemble de votre matériel informatique (support de stockage, etc.).

5- Prenez soin de vos informations personnelles en ligne

Chacun est responsable de ce qu'il diffuse sur Internet.

-Ne communiquez jamais d'informations sensibles sur des sites qui ne vous semblent pas suffisamment protégés, surtout lorsque la mention "Non sécurisé" apparaît à gauche de l'adresse du site Internet.

-Veillez à bien identifier les personnes avec qui vous communiquez sur Internet ; en cas de doute sur une identité, contactez cette personne par un autre moyen avant d'effectuer la moindre action ou de répondre à une requête.

6- Protégez votre messagerie électronique

L'hameçonnage (ou phishing en anglais) désigne une technique frauduleuse qui consiste à usurper l'identité d'un organisme connu (banque, opérateurs, etc.) ou d'un proche pour récupérer des informations.

-Ne cliquez jamais sur un lien et/ou une pièce jointe qui vous semblent douteux ; en cas de suspicion, passez la souris sur le lien pour voir apparaître l'adresse vers laquelle il dirige et appréciez sa légitimité.

-Ne répondez jamais à un mail suspect ; au moindre doute, contactez l'expéditeur par un autre canal.

-Activez la double authentification pour sécuriser vos accès si le fournisseur de messagerie le permet.

7- Évitez les réseaux Wi-Fi publics ou inconnus

S'ils peuvent s'avérer très utiles, les réseaux Wi-Fi publics sont une aubaine pour les attaquants. Très faciles d'accès, ces réseaux peuvent être contrôlés pour intercepter vos informations.

-Désactivez les connexions sans-fil (Wi-Fi, Bluetooth, NFC, etc.) lorsque vous ne vous en servez pas pour éviter que vos appareils s'y connectent automatiquement.

-Lorsque cela est possible, préférez le partage de connexion depuis votre mobile ; sécurisez la connexion avec un mot de passe robuste.

-Si vous n'avez d'autre choix que d'utiliser un Wi-Fi public, veillez à ne jamais y réaliser d'opérations à caractère sensible (paiement par carte bancaire, déclaration d'impôts, renseignement d'informations confidentielles, etc.) et utilisez, si possible, un réseau privé virtuel (VPN).

8- Sauvegardez régulièrement vos données

Effectuez des sauvegardes régulières de vos données personnelles et professionnelles sur des supports distincts selon les usages, et placez-les en sécurité. Cela vous protège en cas de panne, de perte, de vol, de destruction de votre matériel ou d'attaque informatique.

- Utilisez des stockages externes (clé USB, disque dur, etc.) ou optez pour un service de stockage en ligne (cloud).
- Privilégiez les capacités de stockage mises à disposition par votre entreprise pour vos données professionnelles.
- Chiffrez le contenu de vos appareils de stockage.
- Réalisez des sauvegardes non connectées de manière régulière.

9- Protégez-vous des virus et autres logiciels malveillants

Sur Internet, les logiciels malveillants (virus, vers, cheval de Troie, logiciel espion, etc.) représentent un risque réel. Ils sont distribués par de nombreux vecteurs dont vous pouvez vous protéger grâce à :

- Un antivirus dont vous respectez les recommandations (mise à jour des bases virales, suppression ou mise en quarantaine des fichiers suspects).
- Un pare-feu bien configuré qui bloquera les connexions non désirées depuis et vers votre ordinateur.

L'utilisation de ces outils ne sera efficace qu'à condition d'y associer quelques bonnes pratiques :

- N'utilisez jamais un service ou un équipement inconnu ou abandonné (une clé USB par exemple).
- Attribuez un usage spécifique à chaque clé USB pour réduire les effets d'une éventuelle contamination.

10- Accordez le juste niveau de privilèges

Plusieurs personnes peuvent avoir accès au même poste de travail avec un accès plus ou moins restreint, défini selon leurs besoins.

Lorsqu'il vous revient d'ajouter des utilisateurs à un appareil ou à un service, et donc de choisir le niveau de permission à leur accorder, appliquez toujours la règle du privilège minimum et assurez-vous que chacun des utilisateurs ait uniquement les permissions dont il a besoin. Par défaut, tous les utilisateurs d'un poste de travail ou d'un serveur doivent avoir un niveau d'accès limité au système d'exploitation et aux informations. Ensuite, il vous revient de personnaliser les attributions et possibilités de chacun.

IV. Conclusion

Cette analyse confirme que le respect du cadre légal est indissociable de la mise en place de mesures techniques robustes.

Les solutions proposées visent à réduire les risques de violation de données tout en garantissant la conformité réglementaire.

Une validation auprès du responsable de la conformité (DPO) ainsi qu'une phase de test technique sont recommandées avant le déploiement.

V. Sources des recherches

- Principes de base du RGPD

Règlement (UE) 2016/679 du Parlement européen et du Conseil du 27 avril 2016 (RGPD)

[CNIL - Données de santé](#)

[CNIL - Traitement des données de santé et RGPD](#)

- Obligations légales

[Devoirs généraux des médecins](#)

[CNIL](#)

[Système National des Données de Santé](#)

[Droits des utilisateurs](#)

- Actions à entreprendre

- La sécurité du réseau

- La sécurité des données

[Les 10 règles d'or en matière de sécurité numérique](#)